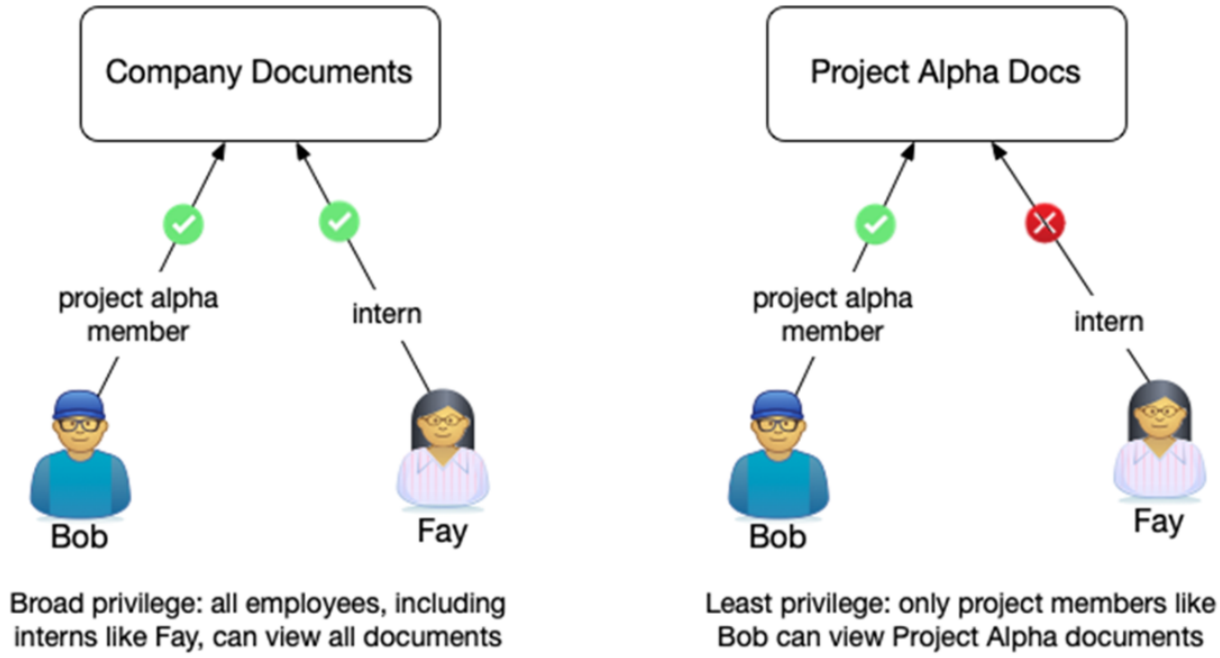


Figure 10.2 Overly broad versus least-privilege scope. Giving all employees access to all documents exposed sensitive financial forecasts in Project Alpha. Restricting access to only project members enforces the principle of least privilege.

By revising the policy to apply solely to project members, ACME ensured that sensitive documents remained accessible only to those with a legitimate need, closing the gap that had allowed Fay to see forecasts.

10.1.3 Separation of policy and data

Policies should focus on logic, not on facts. Embedding data values directly into a policy makes it brittle and difficult to manage. At ACME, a developer once wrote a deployment policy that listed department names explicitly. When the company reorganized and HR renamed Engineering to Product Development, Alice suddenly couldn't deploy her code, even though her responsibilities remained unchanged.

BRITTLE POLICY (HARD-CODED DATA)

Here's the problematic version: